ENTERPRISE SECURITY ARCHITECTURE REPORT • v2.7.0

របាយការណ៍សង្ខេបប្រព័ន្ធសុវត្ថិភាពទាំងមូលនៃកម្មវិធី Cambodia Flavors & Tourism (Khmer Food & Tourism)

ការការពារ ៦ ស្រទាប់ (Defense-in-Depth)៖ ការបំបាំងកូដ, ការពារការក្លូន APK, ការពារ Server & API, សុវត្ថិភាពវិក្កយបត្រ VIP និងការការពារទិន្នន័យអ្នកប្រើប្រាស់

PACKAGE ID ផ្លូវការ	ជំនាន់កម្មវិធី (VERSION)	ប្រព័ន្ធ SERVER	ស្ថានភាពធ្វើតេស្តសុវត្ថិភាព
com.khmerfood.tourism	**v2.7.0 (iOS & Android)**	**Supabase Edge + RLS**	251 / 251 **Checks Passed**

ស្រទាប់ទី ១៖ Code Obfuscation, Anti-Debugging & Anti-Clone Protection

ACTIVE • CLIENT & NATIVE SHIELD

- **ការបំបាំងកូដ និងឈ្មោះឯកសារទិន្នន័យ (Code & Chunk Obfuscation)**៖ នៅក្នុង `vite.config.ts` បានបិទ `sourcemap: false` លុប Comment កូដ និងបំប្លែងឈ្មោះឯកសារទិន្នន័យទាំងអស់ក្នុង `dist/assets/` ទៅជាកូដសម្ងាត់ (`assets/k-[hash].js`, `assets/c-[hash].js`) មិនឱ្យអ្នកណាមើលឃើញឈ្មោះបញ្ជីម្ហូប ឬហាងឡើយ។
- **Android R8 / ProGuard Hardening** (`proguard-rules.pro`)៖ បើក `minifyEnabled true`, `shrinkResources true`, `-optimizationpasses 5` និង `-renamesourcefileattribute SourceFile` ដើម្បីការពារការ Decompile កូដ Java។
- **ការបិទការភ្ជាប់ឧបករណ៍បំបែកកូដ (Anti-Debugging)**៖ នៅក្នុង `MainActivity.java` បានបិទ `WebView.setWebContentsDebuggingEnabled(false)` សម្រាប់កំណែ Production និងបិទគ្រាប់ចុច Inspect (`F12`, `Ctrl+Shift+I/J/C`, `Ctrl+U`, `Ctrl+S`) តាមរយៈ `installRuntimeAntiDebugGuard()`។
- **ការចាប់កម្មវិធីក្លូន និងឧបករណ៍ Hack** (`NativeAppIntegrityPlugin.java`)៖ ត្រួតពិនិត្យ Package ID (`com.khmerfood.tourism`), ហត្ថលេខាឌីជីថលផ្លូវការ `SHA-256`, ចាប់កម្មវិធីក្លូន (*Parallel Space, Dual Space, App Cloner, VirtualApp*) និងចាប់ឧបករណ៍ Hack (*Xposed, Frida, Substrate*)។ បើរកឃើញថាជាកម្មវិធីក្លែងក្លាយ Server នឹងបិទមុខងារ Cloud និង AI ភ្លាមៗ (`TAMPERED_CLONE`)។

ស្រទាប់ទី ២៖ សុវត្ថិភាពគណនី Admin និងការគ្រប់គ្រងប្រព័ន្ធ (Server-Side Admin Security)

ACTIVE • ZERO HARDCODED SECRETS

- **គ្មានលេខសម្ងាត់ Admin ក្នុងកូដកម្មវិធី៖** លេខសម្ងាត់ (Password) និងលេខកូដ PIN របស់ Admin មិនត្រូវបានរក្សាទុកក្នុងទូរស័ព្ទ ឬក្នុងកូដ APK ឡើយ។
- **ការបំប្លែងកូដសម្ងាត់កម្រិតខ្ពស់** (`PBKDF2-SHA256`)៖ នៅក្នុង `supabase/functions/admin-auth/index.ts` លេខសម្ងាត់ និង PIN ត្រូវបានបំប្លែងដោយ `PBKDF2-SHA256 (100,000 iterations + Unique Random Salt)` និងរក្សាទុកក្នុងតារាងសម្ងាត់ `public.kft_security_config`។
- **Signed HMAC-SHA256 Admin Token & Rate Limiting៖** រាល់ការកែប្រែទិន្នន័យសំខាន់ៗត្រូវមាន Token អនុញ្ញាតពី Server និងមានប្រព័ន្ធទប់ស្កាត់ការវាយលេខសម្ងាត់ខុសច្រើនដង (Brute-Force Protection)។

ស្រទាប់ទី ៣៖ សុវត្ថិភាពការទូទាត់ប្រាក់ VIP និងការពារវិក្កយប័ត្រក្លែងក្លាយ (VIP Payment Security)

ACTIVE • ANTI-REPLAY LEDGER

- **តម្លៃកញ្ចប់កំណត់ដោយ Server (Server-Authoritative Pricing)៖** នៅក្នុង `supabase/functions/vip-purchase/index.ts` តម្លៃកញ្ចប់ VIP ទាំងអស់ត្រូវបានផ្ទៀងផ្ទាត់នៅលើ Server មិនអនុញ្ញាតឱ្យកែតម្លៃពីទូរស័ព្ទឡើយ។
- **ការត្រួតពិនិត្យវិក្កយប័ត្រ ABA ៤ ជាន់** (`receipt-rules.ts`)៖ ត្រួតពិនិត្យឈ្មោះអ្នកទទួលប្រាក់ផ្លូវការ (`CHEA KIMSENG / 095 245 959`), ចំនួនទឹកប្រាក់ USD ត្រឹមត្រូវ, កាលបរិច្ឆេទថ្មីពិតប្រាកដ និងលេខប្រតិបត្តិការ (`Trx ID`) រួមទាំងការផ្ទៀងផ្ទាត់ជាមួយរបាយការណ៍ធនាគារ (Bank Statement Matcher)។
- **ការពារការប្រើវិក្កយប័ត្រស្ទួន** (`kft_payment_receipts` & `kft_used_aba_transactions`)៖ លេខប្រតិបត្តិការ (`Trx ID`) មួយអាចប្រើបានតែ ១ ដងគត់នៅទូទាំងប្រព័ន្ធ មិនអាចយកវិក្កយប័ត្រចាស់មកបន្តសុពលភាព VIP ម្តងទៀតបានឡើយ។
- **ត្រាសុវត្ថិភាពគណនី VIP** (`HMAC-SHA256 Integrity Seal`)៖ នៅក្នុង `securityIntegrityGuard.ts` គណនីអ្នកប្រើនីមួយៗត្រូវបានចាក់សោដោយហត្ថលេខាឌីជីថល ការពារការកែថ្ងៃផុតកំណត់ VIP នៅក្នុងម៉ាស៊ីន។

ស្រទាប់ទី ៤៖ ការការពារការបន្លំប្រើ Free Trial 7 ថ្ងៃច្រើនដង (Two-Line Trial Anti-Abuse)

ACTIVE • DEVICE & PHONE HASH

- **ការចងភ្ជាប់លេខសម្គាល់ម៉ាស៊ីន + លេខទូរស័ព្ទ** (+855) **+ អ៊ីមែល៖** បំប្លែងលេខទូរស័ព្ទ អ៊ីមែល Gmail និង Device Fingerprint ទៅជាកូដ `SHA-256` រក្សាទុកក្នុងតារាងសម្ងាត់លើ Server (`supabase_pricing_trial_shop_v1.sql`) ដើម្បីឱ្យទូរស័ព្ទ ១ គ្រឿង ឬលេខទូរស័ព្ទ ១ ខ្សែ អាចបើក Free Trial 7 ថ្ងៃបានតែ ១ ដងគត់ ទោះបីលុបកម្មវិធីដំឡើងថ្មីក៏ដោយ។
- **ការកំណត់កូតា AI ប្រចាំថ្ងៃលើ Server** (`common.ts`)៖ កំណត់ចំនួនប្រើប្រាស់ AI នៅលើ Server ផ្ទាល់ (Free / Trial 7 ថ្ងៃ = `15 ដង/ថ្ងៃ`, សមាជិកបង់ប្រាក់ VIP = `80 ដង/ថ្ងៃ`)។

ស្រទាប់ទី ៥៖ សុវត្ថិភាព API Keys, ការពារការលួចរូបភាព និងការការពារទិន្នន័យអ្នកប្រើប្រាស់

ACTIVE • CLOUD & DATA SAFETY

- **លាក់កូដសម្ងាត់ API ទាំងអស់នៅលើ Server**៖ កូដ Google Maps Places API, Gemini AI និង OpenAI ស្ថិតនៅក្នុង Supabase Edge Function Secrets (`food-ai` , `places-proxy` , `social-food-discovery`) ដោយមានការកំណត់ Field Mask និង Rate Limiter ការពារការបូមទិន្នន័យ (Anti-Scraping)។
- **ការពាររូបភាពម៉ូប និងហាង**៖ បិទការចុចពីលើរូបភាពឱ្យជាប់ដើម្បីទាញយក (`contextmenu` / `dragstart` protection) និងបិទការបង្ហោះរូបភាពឯកជនទៅកាន់សេវាកម្មសាធារណៈក្រៅប្រព័ន្ធ។
- **ប្រព័ន្ធការពារមិនឱ្យបាត់ទិន្នន័យអ្នកប្រើប្រាស់ពេល Update App** (`verifyUserDataSafety.mjs`)៖ មានប្រព័ន្ធ *Aggregate Shrink Guard* (ការពារការលុបបញ្ជីអ្នកប្រើដោយចៃដន្យ), *Durable Outbox* និង *Pre-Update Database Backup Snapshot*។

តារាងសង្ខេបលទ្ធផលត្រួតពិនិត្យសុវត្ថិភាពស្វ័យប្រវត្តិ (Automated Security Audit Suites)

100% VERIFIED

ផ្នែកត្រួតពិនិត្យ (Security Test Suite)	ឯកសារត្រួតពិនិត្យ (Audit Script)	ចំនួនវិញ្ញាសា	លទ្ធផល
Edge Functions, Admin Auth, VIP Anti-Replay, Code Obfuscation & Anti-Clone	`scripts/verifyEdgeFunctions.mjs`	59 Checks	✓ **PASSED** (59/59)
User Data Safety, Anti-Shrink Guard & Cloud Sync Integrity	`scripts/verifyUserDataSafety.mjs`	26 Checks	✓ **PASSED** (26/26)
Apple App Store Security & Privacy Compliance (iOS Guidelines)	`scripts/verifyIosReview.mjs`	11 Checks	✓ **PASSED** (11/11)
AI Assistant Gateway, Consent & Quota Security	`scripts/foodAiAudit.cjs`	155 Checks	✓ **PASSED** (155/155)